

CYBERSECURITY

UNIT 1 — HANDWRITTEN NOTES

KU MCA • Semester 1

Notebook-style, exam-ready revision notes covering all 10 Unit-1 topics.

The 50 cyberattack definitions in the final section are taken from the uploaded Cyberattacks presentation and formatted as revision notes.

1. Introduction to Cybersecurity

Definition: Cybersecurity is the practice of protecting computers, networks, applications, devices and digital information from unauthorized access, misuse, disruption, damage and other cyber threats.

Importance: Modern education, banking, healthcare, communication, business and government services depend heavily on digital systems. Therefore, protecting digital information and services is essential for maintaining confidentiality, integrity and availability.

History — short exam note

- Early computer security mainly focused on physical and local access control.
 - As computer networks and the Internet grew, threats expanded to viruses, worms, unauthorized access and network attacks.
 - Web services, smartphones, cloud computing and connected devices further increased the attack surface.
 - Modern cybersecurity combines technology, policies, awareness, monitoring, incident response and risk management.

Relevance: Cybersecurity is important to individuals, organizations and governments because cyber incidents can affect data, privacy, money, operations and reputation.

Major incidents: Major malware outbreaks, ransomware campaigns, data breaches and attacks on online services have demonstrated that cyber risk can affect both individual users and large organizations.

2. Basic Terminology

Asset: Anything valuable that needs protection, such as data, hardware, software, accounts or services.

Threat: A potential cause of harm to a system, organization or information.

Vulnerability: A weakness in hardware, software, configuration, process or human behavior that can be exploited.

Exploit: A method or technique used to take advantage of a vulnerability.

Risk: The possibility of loss or harm when a threat can exploit a vulnerability.

Attack: An intentional attempt to compromise confidentiality, integrity, availability or another security property.

Authentication: The process of verifying the identity of a user, device or system.

Authorization: The process of determining what an authenticated user or system is allowed to access or do.

Encryption: Converting readable data into a protected form to prevent unauthorized understanding.

Firewall: A security control that monitors and filters network traffic according to defined rules.

3. CIA Triad

The CIA Triad is a basic information-security model consisting of Confidentiality, Integrity and Availability.

A. Confidentiality

Confidentiality means preventing unauthorized people or systems from accessing sensitive information. It is supported by access control, authentication, authorization, encryption and proper information handling.

B. Integrity

Integrity means maintaining the accuracy, completeness and trustworthiness of information. Hashing, checksums, digital signatures, access control and change monitoring can support integrity.

C. Availability

Availability means ensuring that authorized users can access systems, services and information when required. Backups, redundancy, maintenance, monitoring and DoS protection support availability.

Exam line: CIA = Confidentiality + Integrity + Availability.

4. Cyber Attacks — Classification

A cyber attack is an intentional attempt to gain unauthorized access, steal information, alter data, disrupt services or otherwise compromise a digital system.

Common classifications

- Network-based: attacks that target communication, network services or network infrastructure.
- Application/Web: attacks that exploit application logic, inputs, sessions or access controls.
- Malware: attacks using malicious software such as ransomware, worms, trojans or spyware.
- Social engineering: attacks that manipulate people into revealing information or taking unsafe actions.
- Credential attacks: attacks aimed at passwords, tokens or authentication information.
- Physical/insider-related: attacks involving physical access or misuse of legitimate access.

Main effects: Cyber attacks may compromise confidentiality, integrity, availability, authentication, privacy or financial resources.

5. Cyber Crimes — Classification

Cyber crime refers to unlawful activity in which a computer, digital device, network or online service is used as a target, tool or environment for the crime.

Major categories

- Crimes against individuals — identity theft, online harassment, impersonation, fraud and privacy violations.
- Crimes against property — unauthorized use, data theft, intellectual-property violations and damage to digital assets.
- Crimes against organizations — unauthorized access, ransomware, data breaches, service disruption and insider misuse.
- Crimes against society — large-scale fraud, distribution of illegal content and attacks affecting public digital services.
- Crimes involving governments/critical services — unauthorized access, disruption and other attacks against government or critical systems.

6. Cyber Laws and Penalties — IT Act, 2000

The Information Technology Act, 2000 is India's principal legislation dealing with legal recognition of electronic records and electronic transactions and with various cyber-related offences and legal provisions.

Key areas commonly studied

- Legal recognition of electronic records and electronic signatures.
 - Provisions relating to unauthorized access, damage and other computer-related offences.
 - Provisions addressing identity theft, cheating by personation using computer resources and privacy-related offences.
 - Rules and responsibilities relating to intermediaries and certain protected/critical computer resources.
 - Penalties and other consequences depend on the particular provision and facts of the case.

Exam note: If an answer requires exact section-wise penalties, use the current text of the IT Act and applicable amendments/rules.

7. System Security

System security is the protection of computer systems, operating systems, devices and their resources against unauthorized access, malware, misuse, modification and disruption.

Important controls

- Strong authentication and least-privilege access
 - Regular operating-system and software updates
 - Anti-malware protection and secure configuration
 - Firewalls and host-based controls
 - Secure backups and recovery procedures
 - Logging, monitoring and incident response
 - Physical protection of devices

8. Software Security

Software security is the practice of designing, developing, testing and maintaining software so that it resists unauthorized access, misuse and common security vulnerabilities.

Secure software practices

- Secure requirements and threat modelling
 - Input validation and safe output handling
 - Strong authentication and authorization
 - Secure error handling and logging
 - Dependency and patch management
 - Code review and security testing
 - Secure handling of secrets and sensitive data

9. Web Security

Web security is the protection of websites, web applications, APIs, servers and users from attacks that exploit weaknesses in web technologies or application logic.

Common web-security concerns

- Injection attacks
 - Cross-Site Scripting (XSS)
 - Cross-Site Request Forgery (CSRF)
 - Broken access control
 - Authentication and session weaknesses
 - Security misconfiguration
 - Insecure handling of sensitive information

Basic protection: Validate input, enforce authorization on the server, use secure session controls, protect credentials, apply updates and follow secure development practices.

10. Network Security

Network security is the protection of network infrastructure, communication channels, devices and transmitted data from unauthorized access, misuse, interception and disruption.

Major controls

- Firewalls and network segmentation
 - Secure protocols and encryption
 - Intrusion detection/prevention systems
 - Access control and authentication
 - Secure wireless configuration
 - Network monitoring and logging
 - Regular patching and vulnerability management

50 Common / Popular Cyberattacks

Source: uploaded 50-Cyberattacks presentation. The wording below is retained from that source and formatted for revision.

01. Phishing

Phishing is a cyberattack in which an attacker uses deceptive emails, messages, websites, phone calls, or other communications to trick a victim into revealing sensitive information or performing an unsafe action. The attacker commonly pretends to be a trusted person or organization, such as a bank, university, company, or online service. The message may create urgency, fear, curiosity, or a reward so that the victim clicks a malicious link, opens an attachment, enters credentials, or transfers information. Successful phishing can lead to stolen passwords, financial loss, malware infection, identity theft, or unauthorized access to accounts and systems.

02. Malware Attack

A malware attack occurs when an attacker uses malicious software designed to damage, disrupt, spy on, manipulate, or gain unauthorized access to a computer system, network, or device. Malware is a broad term that includes viruses, worms, trojans, spyware, ransomware, and other malicious programs. Malware may enter through unsafe downloads, malicious attachments, compromised websites, removable media, or exploited vulnerabilities. Once executed, it may steal information, modify files, create unauthorized access, consume system resources, or spread to other devices. The impact depends on the malware's purpose and the privileges available to it.

03. Ransomware Attack

A ransomware attack is a form of malware attack in which malicious software prevents victims from accessing files, systems, or services, commonly by encrypting data, and the attacker demands a ransom for restoration or another promised form of access. Modern ransomware operations may also steal sensitive information before encryption and threaten to publish it, a practice commonly called double extortion. Such attacks can interrupt business, education, healthcare, and government operations and may cause financial, operational, legal, and reputational damage. Recovery generally depends on secure backups, incident response, containment, and restoration procedures.

04. Denial-of-Service (DoS) Attack

A Denial-of-Service (DoS) attack is an attack intended to make a computer, network, application, or online service unavailable or difficult for legitimate users to access. The attacker attempts to exhaust a limited resource such as bandwidth, processing power, memory, connection capacity, or application resources. As the system becomes overloaded, legitimate requests may be delayed, rejected, or dropped. A DoS attack normally originates from a single attacking source or a relatively limited number of sources. Its main security objective is to affect availability rather than directly steal information.

05. Distributed Denial-of-Service (DDoS) Attack

A Distributed Denial-of-Service (DDoS) attack is a denial-of-service attack carried out through many compromised or coordinated devices at the same time. These devices may form a botnet or otherwise generate large volumes of malicious traffic or requests toward a target. Because the traffic comes from multiple sources, blocking one attacking device is not enough to stop the attack. DDoS attacks can consume network bandwidth, overload servers, exhaust connection tables, or overwhelm application resources. The primary impact is reduced availability, which can prevent legitimate users from reaching a service.

06. Man-in-the-Middle (MITM) Attack

A Man-in-the-Middle (MITM) attack occurs when an attacker secretly positions themselves between two communicating parties and interferes with the exchange of information. Instead of communication going directly between the legitimate parties, the attacker may observe, relay, modify, delay, or replace messages. The attack can be used to steal credentials, session information, financial data, or other sensitive information, and in some situations to alter transactions. Strong encryption, certificate validation, secure network configurations, and multi-factor authentication can reduce the risk of successful interception or manipulation.

07. Social Engineering Attack

A social engineering attack is a cyberattack that manipulates human behavior rather than relying only on a technical vulnerability. The attacker uses deception, impersonation, trust, fear, urgency, curiosity, authority, or helpfulness to persuade a victim to disclose information, open a file, click a link, transfer money, or provide access. Common examples include phishing, pretexting, baiting, quid pro quo, tailgating, and vishing. Social engineering is dangerous because even well-protected technical systems can be affected when a legitimate user is persuaded to perform an action that benefits the attacker.

08. Brute-Force Attack

A brute-force attack is an authentication attack in which an attacker systematically tries many possible passwords, PINs, keys, or other combinations until a correct value is found. The method does not necessarily depend on knowing the victim's password; instead, it relies on repeated guesses. The number of possible combinations and the strength of the password determine how difficult the attack is. Automated tools can make large numbers of attempts quickly when a service permits them. Account lockout, rate limiting, strong passwords, multi-factor authentication, and monitoring can significantly reduce brute-force risk.

09. SQL Injection

SQL Injection is an injection attack in which an attacker places malicious SQL-related input into an application's data fields or requests so that the application's database query is changed from its intended meaning. It usually occurs when an application builds SQL statements from untrusted input without using safe query construction and validation. Depending on the vulnerability and database permissions, an attacker may read, modify, delete, or otherwise manipulate database information and may sometimes affect other database operations. Parameterized queries, appropriate input handling, least privilege, and secure database configuration are important

defenses.

10. Cross-Site Scripting (XSS)

Cross-Site Scripting (XSS) is a web security attack in which an attacker causes malicious client-side script, commonly JavaScript, to be delivered and executed in a victim's browser through a trusted web application. XSS generally occurs when an application improperly handles untrusted input or output and fails to apply suitable encoding or sanitization. Depending on the type and context, an XSS vulnerability can allow malicious actions in the victim's browser, access to information available to the script, session abuse, or modification of displayed content. Context-aware output encoding, safe frameworks, validation, and suitable security controls help prevent XSS.

11. Trojan Horse Attack

A Trojan Horse attack uses a malicious program that is disguised as legitimate, useful, or desirable software, a document, media file, update, or other content. Unlike a worm, a Trojan generally relies on the victim or another process to execute or install it rather than automatically spreading itself. After execution, the Trojan may install additional malware, steal information, provide unauthorized remote access, modify files, or perform other malicious activities. Because the program may appear trustworthy, social engineering and fake software downloads are common delivery methods. Application allow-listing, trusted sources, updates, and endpoint security can reduce risk.

12. Password Attack

A password attack is any attack that attempts to obtain, guess, steal, reuse, or otherwise compromise a user's password or password-based authentication. It includes techniques such as brute-force guessing, dictionary attacks, password spraying, credential stuffing, phishing, keylogging, and theft of password databases. Once a password is compromised, attackers may access the associated account and may attempt to reuse the same credential elsewhere. Strong unique passwords, password managers, multi-factor authentication, secure password storage, rate limiting, and monitoring are important defenses against password attacks.

13. Spear Phishing

Spear phishing is a targeted form of phishing in which an attacker researches a specific person, group, or organization and creates a customized deceptive message to make the attack appear credible. Instead of sending a generic message to thousands of people, the attacker may use the victim's name, job role, organization, current projects, colleagues, or other publicly available information. The objective may be to steal credentials, deliver malware, obtain confidential information, or persuade the victim to perform a financial or administrative action. Because the communication is personalized, spear phishing can be harder to recognize than generic phishing.

14. Credential Stuffing Attack

Credential stuffing is an account-compromise attack in which an attacker uses previously leaked username-and-password combinations from one service to attempt authentication against other services. It succeeds because people sometimes reuse the same password across multiple websites or applications. The attacker automates large numbers of login attempts and relies on the fact that some reused credentials will remain valid elsewhere. Credential stuffing is different from brute force because the attacker generally starts with known or leaked credential pairs rather than generating every possible password. Unique passwords, password managers, MFA, bot detection, and breached-password screening reduce the risk.

15. Zero-Day Attack

A zero-day attack exploits a software or hardware vulnerability that is unknown to the affected vendor or for which no effective security fix was available when exploitation began. The term 'zero-day' refers to the defender having had zero days of prior warning or remediation opportunity. A zero-day can be particularly difficult to detect

and prevent because traditional patching cannot immediately address the underlying flaw. Attackers may use such vulnerabilities to gain unauthorized access, execute code, steal data, or disrupt systems. Rapid threat intelligence, behavior-based detection, segmentation, least privilege, and timely vendor patches after disclosure help reduce exposure.

16. Session Hijacking

Session hijacking is an attack in which an attacker takes control of or interferes with a user's authenticated session after login, often by obtaining or abusing the session identifier or session secret. A session allows an application to recognize an authenticated user without requiring credentials for every request. If an attacker obtains a valid session token, the attacker may be able to impersonate the user until the session expires or is invalidated. Risks can be reduced through secure cookies, HTTPS, appropriate session expiration, token rotation, secure session management, and protection against token theft.

17. DNS Spoofing

DNS spoofing is an attack in which an attacker causes false Domain Name System information to be supplied to a victim or DNS resolver so that a domain name is associated with an incorrect IP address or destination. As a result, a user may believe they are connecting to a legitimate website while being redirected to an attacker-controlled system. The fraudulent destination may be used for phishing, credential theft, malware delivery, or traffic interception. DNSSEC, secure resolver configuration, protective DNS services, certificate validation, and careful network monitoring can help reduce the impact of DNS spoofing.

18. ARP Spoofing

ARP spoofing is a local-network attack in which an attacker sends forged Address Resolution Protocol (ARP) messages to associate the attacker's MAC address with another device's IP address, such as the default gateway. Devices on the local network may then send traffic to the attacker instead of the intended destination. This can allow traffic interception, modification, or disruption and may support a man-in-the-middle attack. ARP spoofing is mainly relevant to local or shared network environments. Network segmentation, secure switching features, static or protected ARP configurations, encryption, and monitoring can reduce the risk.

19. Command Injection

Command injection is an attack in which an attacker causes an application to execute unintended operating-system commands by supplying specially crafted input to a function that invokes a command interpreter or system utility. The vulnerability usually occurs when untrusted input is concatenated into a system command without safe separation between data and commands. If successful, the attacker may execute actions with the privileges of the vulnerable application, potentially reading files, changing system settings, or affecting other resources. Avoiding shell interpretation, using safe APIs, strict allow-list validation, and least privilege are key defenses.

20. Buffer Overflow Attack

A buffer overflow attack occurs when a program writes more data into a fixed-size memory buffer than the buffer can safely hold, causing data to overwrite adjacent memory. The overwritten memory may contain control information, program data, or other important values. Depending on the programming language, architecture, and security protections, an attacker may cause a crash, alter program behavior, or potentially achieve unauthorized code execution. Secure memory handling, bounds checking, memory-safe programming languages, compiler protections, address-space layout randomization, and non-executable memory are important defensive measures.

21. Supply Chain Attack

A supply chain attack targets the relationships, software, hardware, services, vendors, dependencies, or update mechanisms that an organization trusts rather than attacking the final target directly. An attacker may compromise a supplier, developer environment, software dependency, build system, distribution channel, or service provider and use that trusted position to reach downstream victims. Because the malicious component may arrive through a legitimate channel, detection can be difficult. Software bill of materials, vendor assessment, signed updates, dependency management, build security, access controls, monitoring, and verification of third-party components help reduce supply-chain risk.

22. Insider Attack

An insider attack is a security incident caused or enabled by a person who has legitimate access to an organization's systems, facilities, data, or resources. The insider may be a current employee, contractor, administrator, partner, or another trusted user. The behavior can be intentional, such as stealing information or deliberately damaging systems, or unintentional, such as exposing data through negligence or unsafe actions. Insider attacks are difficult because legitimate credentials may be used. Least privilege, separation of duties, access reviews, logging, monitoring, security awareness, and strong offboarding procedures can reduce the risk.

23. Email Spoofing

Email spoofing is the creation or transmission of an email message that falsely appears to come from a trusted sender, person, organization, or domain. Attackers may manipulate message information so that the visible sender identity looks legitimate even though the message was not actually sent by that source. Spoofed emails are frequently used in phishing, business email compromise, malware delivery, and fraud. Email authentication technologies such as SPF, DKIM, and DMARC can help organizations detect or reduce unauthorized use of their domains, while users should independently verify unusual requests for money, credentials, or sensitive information.

24. Pharming Attack

Pharming is an attack that redirects users from a legitimate website or domain to a fraudulent destination, often without requiring the victim to click a malicious link. The redirection can be achieved through manipulation of DNS information, compromised hosts, malicious software, or changes to local network or device configuration. The victim may enter usernames, passwords, payment details, or other information into the fake site because the redirection can appear unexpected or legitimate. Secure DNS services, DNSSEC where applicable, endpoint protection, secure configuration, and checking certificate and domain information can help reduce the risk.

25. Whaling Attack

Whaling is a highly targeted form of phishing that focuses on senior executives, high-value employees, or individuals with significant authority or access to sensitive information and financial resources. The attacker researches the target and creates a convincing message that may imitate a senior colleague, business partner, lawyer,

bank, or other trusted party. The objective may be to obtain credentials, confidential information, approve a payment, or authorize another sensitive action. Because senior personnel may have broad privileges, a successful whaling attack can have significant organizational consequences. Verification procedures and strong authentication are important defenses.

26. Evil Twin Attack

An Evil Twin attack occurs when an attacker creates a fraudulent wireless network that imitates a legitimate Wi-Fi network, often using a similar or identical network name. Victims may connect because they believe the network is an official hotspot, office network, hotel network, or public Wi-Fi service. Once connected, the attacker may attempt to observe traffic, redirect users to malicious pages, or capture information that is not adequately protected. Using trusted networks, verifying Wi-Fi details, avoiding sensitive activity on unknown hotspots, and using end-to-end encryption and VPNs where appropriate can reduce exposure.

27. Website Defacement

Website defacement is an attack in which an unauthorized person changes the visible content or appearance of a website. The attacker may replace the normal homepage or other pages with unauthorized text, images, messages, political statements, advertisements, or other content. Defacement generally requires the attacker to obtain unauthorized access to the web server, content management system, hosting account, or another component used to publish the site. It can damage an organization's reputation and may indicate deeper compromise. Secure authentication, patching, access control, backups, file-integrity monitoring, and secure deployment practices help prevent and recover from defacement.

28. Drive-by Download Attack

A drive-by download attack occurs when visiting a compromised or malicious website causes unwanted software or malicious content to be downloaded, and in some cases executed, on the visitor's device. The attack may exploit vulnerabilities in the browser, plugins, operating system, or web application, or may use deceptive prompts to persuade the user to install software. A victim may not realize that an attack occurred because it can happen during ordinary web browsing. Keeping browsers and operating systems updated, using security controls, limiting unnecessary plugins, and avoiding untrusted downloads can reduce the risk.

29. Replay Attack

A replay attack occurs when an attacker captures a valid communication, authentication message, transaction, or token and later retransmits it to make the system accept the old information again. The attacker does not necessarily need to understand or decrypt the original message; the goal is to reuse a valid message at a later time. Replay attacks can affect authentication systems, payment systems, network protocols, and other communications when freshness is not properly enforced. Nonces, timestamps, sequence numbers, short-lived tokens, challenge-response mechanisms, and cryptographic integrity protections are common defenses.

30. Privilege Escalation Attack

A privilege escalation attack occurs when an attacker who has limited access obtains permissions or capabilities beyond those originally assigned to the account or process. In vertical privilege escalation, a lower-privileged user attempts to obtain higher privileges such as administrator or root access. In horizontal privilege escalation, an attacker accesses resources belonging to another user with similar privilege levels. The attack may exploit software vulnerabilities, incorrect permissions, weak configurations, or stolen privileged credentials. Least privilege, secure configuration, patching, access reviews, and strong privilege separation help reduce the risk.

31. Remote Code Execution (RCE)

Remote Code Execution (RCE) is a security condition in which an attacker is able to cause arbitrary code or commands to execute on a target system from a remote location. RCE may result from vulnerabilities such as unsafe deserialization, command injection, memory corruption, insecure software components, or other flaws that allow attacker-controlled input to reach an execution path. Successful RCE can provide a powerful foothold because the attacker may execute actions with the privileges of the vulnerable service. Patching, input validation, isolation, least privilege, secure coding, and monitoring are important defenses.

32. Directory Traversal Attack

A directory traversal attack, also called path traversal, occurs when an attacker manipulates a file or directory path supplied to an application so that the application accesses files outside the intended directory. The attack takes advantage of inadequate validation of file paths and can expose configuration files, source code, credentials, or other sensitive resources. In more severe cases, unsafe file handling can also contribute to unauthorized modification or code execution. Applications should avoid constructing filesystem paths directly from untrusted input, use safe path APIs, apply allow-list validation, enforce permissions, and isolate sensitive files.

33. LDAP Injection

LDAP Injection is an attack against applications that construct Lightweight Directory Access Protocol (LDAP) queries or filters using untrusted user input without proper validation or escaping. By supplying specially crafted input, an attacker may alter the intended LDAP statement and influence directory searches or operations. Depending on the application's privileges and design, this may expose restricted information, bypass intended filtering, grant unauthorized access, or modify directory content. Secure LDAP APIs, correct escaping for LDAP filters and distinguished names, allow-list validation, and least-privilege service accounts are important defenses.

34. XML Injection

XML Injection is an attack in which an attacker inserts malicious or unintended XML content into an application's XML data or document-processing workflow. It can occur when untrusted input is combined with XML without adequate validation, escaping, or safe parser configuration. Depending on the application, manipulated XML may change the structure or meaning of data, bypass application logic, or contribute to other XML-related vulnerabilities such as XML External Entity processing when insecure parser features are enabled. Secure XML libraries, proper encoding, input validation, disabling unnecessary external entities, and secure parser configuration help reduce the risk.

35. Server-Side Request Forgery (SSRF)

Server-Side Request Forgery (SSRF) is an attack in which an attacker abuses a server-side feature that makes network requests so that the server sends a request to an unintended destination. The attacker may manipulate a URL or another request parameter used by functions such as image fetching, webhooks, import tools, or remote resource retrieval. Because the request originates from the server, it may reach internal services that are not directly accessible from the internet. SSRF can

therefore expose internal resources, metadata, or services and may support further attacks. Strict destination allow-lists, network segmentation, and safe URL handling are important defenses.

36. DNS Tunneling Attack

DNS tunneling is a technique in which data or commands are encoded within DNS queries and responses to create a covert communication channel. DNS is widely permitted through network boundaries because normal systems require it for name resolution, so attackers may abuse this trusted protocol to move information or maintain communication with a remote system. DNS tunneling can be associated with malware command-and-control or data exfiltration. Unusually long or frequent DNS requests, suspicious domains, high query entropy, and abnormal DNS behavior can indicate tunneling. Protective DNS, logging, filtering, and traffic analysis help detect and restrict it.

37. Watering Hole Attack

A watering hole attack occurs when an attacker compromises or prepares a website that members of a particular target group are likely to visit. Instead of directly attacking every victim, the attacker places malicious content or exploit code on a trusted or frequently visited site. When members of the targeted group browse the site, they may be exposed to malware, phishing, or exploitation of browser and system vulnerabilities. The attack is named after the idea of attackers waiting at a place where their intended victims naturally gather. Patching, web isolation, endpoint security, and monitoring of trusted sites help reduce risk.

38. Session Fixation Attack

Session fixation is an authentication attack in which an attacker causes a victim to use a session identifier that the attacker already knows or can predict. After the victim authenticates using that session, the attacker may attempt to reuse the same session identifier to access the authenticated session. The vulnerability commonly results from applications that fail to issue a new session identifier after successful authentication. A key defense is session ID regeneration whenever a user logs in or changes privilege level, together with secure session cookies, HTTPS, expiration, and proper session management.

39. Clickjacking Attack

Clickjacking is a user-interface redressing attack in which a victim is tricked into clicking a visible or apparently harmless element while the actual click is directed toward a hidden or overlaid element from another page. The victim may unknowingly perform actions such as changing settings, submitting forms, granting permissions, or interacting with an account. The attack abuses the difference between what the user believes they are clicking and what the browser actually receives. Security headers such as Content-Security-Policy frame controls and X-Frame-Options, together with appropriate application design, can reduce clickjacking risk.

40. Cryptojacking Attack

Cryptojacking is the unauthorized use of another person's computer, server, cloud resources, or other devices to perform cryptocurrency mining. The attacker may

install malware on a device or use malicious code in a web page to consume the victim's CPU, GPU, electricity, bandwidth, or cloud computing resources. The victim may experience high resource usage, slower performance, overheating, increased energy costs, or unexpected cloud bills. Cryptojacking is primarily a resource-abuse attack rather than a direct attempt to encrypt or steal files. Endpoint monitoring, browser controls, patching, application restrictions, and resource anomaly detection can help identify it.

41. Dictionary Attack

A dictionary attack is a password-guessing technique in which an attacker attempts passwords from a prepared list of likely words, phrases, common passwords, leaked passwords, and predictable variations. It is more efficient than trying every possible combination because many users choose passwords based on common words, names, dates, or patterns. The attacker may automate the attempts against one or more accounts depending on the target. Strong unique passwords, password managers, rate limiting, account protection, multi-factor authentication, and blocking commonly compromised passwords can reduce the success of dictionary attacks.

42. Rainbow Table Attack

A rainbow table attack is a password-cracking technique that uses precomputed tables of password-hash relationships to recover passwords from stolen unsalted password hashes more efficiently than calculating every candidate hash from scratch. A rainbow table stores chains of computations that allow an attacker to search for a matching hash under the assumptions of the particular hashing algorithm and table. Modern password storage should use unique salts and slow, password-specific hashing algorithms, which greatly reduce the usefulness of precomputed tables. Strong passwords and secure password storage practices further improve protection.

43. Typosquatting Attack

Typosquatting is an attack or deceptive practice in which an attacker registers or uses a domain name that is very similar to a legitimate domain, often differing by a common typing mistake, omitted character, extra character, or visually confusing variation. The goal is to attract users who accidentally enter the wrong address or follow a misleading link. The fake site may be used for phishing, malware distribution, advertising, credential theft, or fraud. Users should verify domains carefully, while organizations can monitor look-alike domains, protect important domains, and use email and web security controls.

44. HTTP Request Smuggling

HTTP Request Smuggling is a web attack that exploits differences in how front-end and back-end HTTP components interpret the boundaries of requests. It commonly affects architectures involving proxies, load balancers, gateways, and application servers. When these components disagree about where one request ends and another begins, an attacker may cause part of a crafted request to be interpreted differently by another component. This can enable request routing manipulation, cache poisoning, access-control bypass, or other attacks depending on the environment. Consistent HTTP parsing, secure proxy configuration, patched components, and careful handling of request framing help prevent it.

45. DLL Injection Attack

DLL Injection is a technique in which an attacker causes a running process to load a Dynamic Link Library (DLL) that was not intended by the application or system administrator. Because the injected DLL can execute code within the context of the target process, the attacker may gain the process's privileges or influence its behavior. DLL injection can be used for malicious persistence, credential theft, evasion, or manipulation of applications. Strong application isolation, code-signing

controls, least privilege, secure loading paths, endpoint protection, and operating-system security mechanisms can help prevent unauthorized DLL loading.

46. Code Injection Attack

Code injection is a broad class of attacks in which an attacker supplies data that an application mistakenly interprets as executable code or instructions. The injected content may target a programming language interpreter, template engine, expression language, script processor, or another execution mechanism. The result can range from altered application behavior to unauthorized data access or arbitrary code execution, depending on the affected component. Code injection commonly results from treating untrusted input as executable instructions rather than data. Safe APIs, parameterization, strict input validation, output encoding, and least privilege are important defenses.

47. Smurf Attack

A Smurf attack is a type of distributed denial-of-service attack that abuses Internet Control Message Protocol (ICMP) and network broadcast behavior. In the traditional form, an attacker sends ICMP echo requests using a spoofed source address corresponding to the intended victim and directs them toward a network that permits broadcast amplification. Multiple devices on that network respond toward the spoofed victim address, creating a large amount of traffic. The result can consume the victim's network resources and reduce availability. Modern network configurations commonly disable directed broadcasts and apply anti-spoofing controls to reduce this risk.

48. Teardrop Attack

A Teardrop attack is a denial-of-service technique that exploits how a vulnerable system handles fragmented network packets. The attacker sends overlapping or malformed IP fragments that the target system attempts to reassemble. If the operating system or networking stack cannot correctly handle the unusual fragment information, the reassembly process may fail and cause the system to crash, hang, or become unavailable. Modern operating systems have largely addressed the classic vulnerability, but malformed packet handling remains an important security consideration. Keeping systems patched and using network security monitoring helps protect against related fragmentation-based attacks.

49. Ping Flood Attack

A ping flood attack is a denial-of-service attack in which an attacker sends a very large number of ICMP Echo Request packets, commonly called ping requests, toward a target. Processing and responding to excessive ICMP traffic can consume bandwidth, CPU resources, memory, or network capacity. If the volume is high enough, legitimate users may experience slow connections or complete loss of access. The attack can be especially effective when the target has limited resources or when network capacity is saturated. Rate limiting, filtering, traffic monitoring, and DDoS protection services can help mitigate excessive ICMP traffic.

50. URL Spoofing Attack

URL spoofing is a deceptive technique in which an attacker creates or presents a web address that looks similar to a legitimate URL in order to mislead a user about the

true destination. The fake address may use misspellings, misleading subdomains, confusing characters, URL encoding, or other tricks. The objective is often to make the victim trust a fraudulent website and disclose credentials, payment information, or other sensitive data. Users should inspect the actual domain carefully and avoid entering sensitive information into unexpected sites. Organizations can also use secure DNS, web filtering, phishing protection, and domain monitoring.

Quick Revision — Unit 1

- Cybersecurity protects digital systems, networks, applications and information from cyber threats.
- CIA Triad = Confidentiality + Integrity + Availability.
- Vulnerability is a weakness; a threat is a potential cause of harm; an exploit takes advantage of a vulnerability.
- Cyber attacks can target people, devices, applications, networks and data.
- Cyber crimes are unlawful activities involving computers or digital systems.
- System, software, web and network security require multiple technical and administrative controls.

END OF UNIT 1